

OWASP A01 – BROKEN ACCESS CONTROL

Broken Access Control:

Broken Access Control occurs when an application fails to properly enforce restrictions on what authenticated users are allowed to do. Access control, sometimes called authorization, is how a *web application grants access to content and functions to some users and not others*.

Impacts on Web Applications and Users

1. **Unauthorized Admin Access:**

If the system doesn't verify user roles properly, a regular user could access admin-only features just by modifying a cookie or URL.

2. **Data Exfiltration:**

An attacker could view or download private user data, such as claims or personal information, by guessing other user IDs.

3. **Account Takeover:**

If session cookies are not protected, an attacker could pretend to be another user and gain full access to their account.

4. **Financial Fraud:**

If users can modify payment or claim information without proper checks, they could change amounts or approve their own claims.

5. **Regulatory Fraud:**

If sensitive user data is exposed, the company could face legal penalties and loss of trust.

Real-World Examples

1. **US Equifax Data Breach (July 2017)**

Impact: 147 million people affected

What happened:

Attackers exploited a web application vulnerability and gained access to sensitive consumer data.

Data exposed:

SIN numbers, Birth dates, Addresses

Why it relates to Broken Access Control:

The system failed to properly restrict access to sensitive data once attackers were inside.

Consequences:

- \$700 million settlement
- Massive Reputation damage

2. US Facebook Access Token Exposure (Sept. 2018)

Impact: 50 million accounts

What happened:

A vulnerability allowed attackers to steal access tokens (session credentials).

Why it relates to Broken Access Control:

Access tokens act like session cookies. If an attacker steals one, they can log in as the victim.

3. Panera Bread Data Leak (2018)

Organization: Unique Identification Authority of India

What happened:

Customer data was accessible through an insecure API endpoint.

Data exposed:

Names, Email addresses, Phone numbers

Why it relates to Broken Access Control:

The API did not properly restrict who could access customer information.